

Front vs. Back DEV y guía de endpoints

Usuarios, roles y permisos — qué falta implementar en el front, qué cambió y qué se requiere

Front	feature/login-coctel-del-mar-integration (commit ab89ce2) — proyecto reconciliation
Back	rama DEV (commit de23127) — proyecto coctel_midd : auth-service, gateway, sales-service (nuevo), db-migration (nuevo)
Documento nuevo	Guía_Endpoints_Usuarios_Roles_Permisos.pdf (14 pp.). Las dos copias (reconciliation/docs y coctel_midd/docs) tienen contenido idéntico.
Método	La guía se contrastó contra el código real de DEV (controladores, DTO, SecurityConfig, migraciones, gateway), no solo contra lo que dice el PDF. No se modificó nada del back ni de la guía.
Versión	1.0 — 06-Oct-2026 · Responsable portal: Irving Canul

1. Resumen

11

de los 19 endpoints de la guía ya están en el front

8

faltan por implementar (sección 4)

7

de los 11 implementados tienen cambios que exigen ajuste (sección 3)

3

endpoints nuevos de ventas (Sales Service, fuera de la guía)

Hallazgos que más pesan

- Catálogo de permisos distinto.** DEV define 9 permisos: capture_sales es nuevo y view_catalogs **no existe**. El front gatea /catalogos con view_catalogs y lee los permisos que devuelve el back: contra un DEV limpio nadie (ni ADMIN) vería Catálogos.
- La matriz por defecto de DEV no es la del front.** En DEV, Tesorería no tiene view_dashboard, Contabilidad no exporta y Costos no tiene ningún permiso (§5.2). Lo que el front cerró en la matriz 7.16 dependía de un seed manual en la DB local, que DEV no trae.
- Cambio de contraseña:** la guía exige llamar a /auth/refresh justo después; el front no lo hace, así que el token conserva mustChangePassword y los endpoints protegidos responden 403 PASSWORD_CHANGE_REQUIRED hasta el siguiente refresh.
- PATCH /users/{id}/unlock existe en el código de DEV pero no aparece en la guía** (allí el desbloqueo es PATCH .../status {"status":"active"}): el front depende de un endpoint sin documentar.
- Entorno:** DEV mueve el esquema a un módulo db-migration (el auth-service ya no corre Flyway) y el gateway queda en :8080. La DB local actual viene de feature/login: hay que reconstruir la pila y volver a sembrar las 26 cuentas (§6).

2. Matriz comparativa de endpoints

#	Método	Endpoint	Permiso en DEV	Estado en el front	Nota
1	POST	/auth/login	Público	Implementado	Mensaje 423 ahora dice los minutos que faltan; el front muestra un texto fijo.
2	POST	/auth/refresh	Público	Implementado	Sin cambios de contrato.
3	POST	/auth/logout	Público	Implementado	Sin cambios.
4	GET	/auth/me	Sesión	Implementado	Sin cambios.
5	POST	/auth/change-password	Sesión	Ajuste	Falta el refresh posterior (§3).

6	GET	/users	manage_users	Ajuste menor	Autoriza por permiso, no por rol; size por defecto 20.
7	GET	/users/{id}	manage_users	Ajuste	3 campos nuevos sin mapear.
8	POST	/users	manage_users	Ajuste menor	Código de error nuevo INVALID_LOCATION .
9	PATCH	/users/{id}	manage_users	Ajuste	Ahora acepta subsidiariaIds / ubicacionIds .
10	PATCH	/users/{id}/roles	manage_users + manage_roles (roles)	Falta	Hoy local (mock).
11	PATCH	/users/{id}/status	manage_users	Ajuste menor	active también desbloquea; blocked no vence solo.
12	POST	/users/{id}/verify-email	manage_users	Implementado	Sin cambios.
13	POST	/users/{id}/close-sessions	manage_users	Falta	Hoy contador local.
14	POST	/users/{id}/reset-password	manage_users	Falta	Hoy genera contraseña local.
15	DELETE	/users/{id}	manage_users	Falta	Baja lógica; opción retirada del front.
16	GET	/users/{id}/audit-log	view_audit_log	Falta	Hoy bitácora en memoria.
17	GET	/audit-log	view_audit_log	Falta	Hoy bitácora en memoria.
18	GET	/roles	manage_users o manage_roles	Falta	Hoy constante ROLES .
19	GET	/permissions	manage_users o manage_roles	Falta	Hoy constante PERMISSIONS .
—	PATCH	/users/{id}/unlock	manage_users	Sin documentar	Existe en UserAdminController (l.143) pero no en la guía; el front lo usa.

Conteo: 5 de /auth/* + 14 de usuarios/catálogos/bitácora = 19 en la guía. Implementados en el front: 5 de /auth + GET /users , GET /users/{id} , POST /users , PATCH /users/{id} , PATCH .../status , POST .../verify-email = 11 (más unlock , no documentado).

3. Cambios en los endpoints que el front ya implementó

Endpoint	Qué cambió en DEV	Qué requiere el front
POST /auth/change-password	La guía advierte que el token vigente sigue marcado <code>mustChangePassword</code> ; hay que llamar a <code>/auth/refresh</code> inmediatamente después.	<code>AuthService.changePassword()</code> debe encadenar un refresh con el refresh token guardado y reemplazar la sesión; hoy solo apaga <code>mustChangePasswordHint</code> local, y <code>/users</code> responde 403 <code>PASSWORD_CHANGE_REQUIRED</code> hasta el siguiente refresh programado.
POST /auth/login	Bloqueo temporal de 2 h tras 5 intentos (configurable); desbloqueo automático (al intentar entrar y por barrido cada minuto). El 423 trae el mensaje con los minutos restantes.	Opcional: mostrar <code>error</code> del back en lugar del texto fijo de <code>login.ts</code> (<code>BLOCKED_MESSAGE</code>). Revisar el comentario de que el bloqueo "no vence solo".
GET /users	Autorización por permiso <code>manage_users</code> (no por rol ADMIN/ALTAS). <code>size</code> por defecto 20. Filtro <code>status</code> acepta <code>active inactive blocked</code> (y <code>ACTIVE INACTIVE LOCKED</code>).	<code>syncFromBackend()</code> ya manda <code>size=100</code> : solo falta paginar si hay más de 100. Actualizar <code>forbiddenRoleMessage</code> ("rol ADMIN o ALTAS" → falta el permiso <code>manage_users</code>).
GET /users/{id}	<code>UserDetailDto</code> gana <code>failedLoginAttempts</code> , <code>activeSessions</code> y <code>lockedUntil</code> .	Agregarlos a <code>UserDetailDto</code> (<code>auth.service.ts</code>) y a <code>mergeBackendDetail / buildUserFromDetail</code> ; <code>AppUser</code> ya tiene los dos primeros (hoy quedan en el mock), falta <code>lockedUntil</code> . Corrige lo que se informó antes: ya no son campos "no modelados por el back".
POST /users	Nuevo código 400 <code>INVALID_LOCATION</code> (subsidiaria/ubicación inexistente o dada de baja). Correo de un usuario dado de baja se puede reutilizar.	Agregar el código a <code>ERROR_CODE_MESSAGES</code> (<code>auth-errors.ts</code>). Sin él cae al mensaje genérico.
PATCH /users/{id}	<code>UpdateUserRequest</code> ahora acepta <code>subsidiariaIds</code> y <code>ubicacionIds</code> (reemplazo; lista vacía las quita; omitirla no toca nada). Un <code>null</code> explícito no borra un campo de texto. Registra <code>organization_updated</code> .	Reactivar el multi-select de subsidiarias/ubicaciones en modo edición (se había dejado de solo lectura porque antes el endpoint no las modelaba) y enviarlas en <code>updateUserProfile()</code> . Aviso de UX: el front manda <code>null</code> al vaciar un campo, y eso no lo limpia en el back.
PATCH /users/{id}/status	<code>active</code> también desbloquea y borra el vencimiento; <code>blocked</code> es manual y no vence solo (<code>LOCKED</code>).	Sin cambio de contrato. Con esto el desbloqueo se puede hacer con <code>status active</code> (ver unlock abajo).
PATCH /users/{id}/unlock	No documentado en la guía, pero sigue en el código de DEV.	Migrar <code>onUnlockBackendClick</code> a <code>changeStatus(id, 'active')</code> (ya implementado) o confirmar con back que <code>unlock</code> se mantiene.
Todos los de /users/**	Seguridad por <code>hasAuthority</code> : el JWT lleva roles y permisos como autoridades. Los cambios de permisos se ven en el siguiente refresh (máx. 15 min).	Tras cambiar los permisos del propio usuario, forzar un refresh para no esperar. Texto de 403 por permiso, no por rol.
Códigos de error	Nuevos: <code>INVALID_PERMISSION</code> , <code>INVALID_LOCATION</code> , <code>CANNOT_DELETE_SELF</code> (409).	Los 3 a <code>ERROR_CODE_MESSAGES</code> .

4. Endpoints que faltan por implementar

PATCH /users/{id}/roles Guardar roles y permisos · Prioridad alta	
Contrato	Body { roleIds?: string[], permissions?: string[] } (omitido = no tocar; una lista reemplaza por completo). Respuesta: UserSummaryDto . Permiso <code>manage_users</code> ; cambiar roles exige además <code>manage_roles</code> . Errores: 400 INVALID_ROLE / INVALID_PERMISSION , 403 ROLE_ASSIGNMENT_FORBIDDEN , 404.
Hoy en el front	UserManagementService.changeRoles() es local: lo usan UserDetail.onSaveRolesAndPermissions() y UserList.onRoleQuickChange() .
Se requiere	(1) AuthService.updateAccess(id, body) ; (2) volver changeRoles asíncrono y reconciliar con la respuesta; (3) el front calcula los permisos por defecto al cambiar de rol y envía el resultado final — debe leerlos de GET /roles (defaultPermissions), no de la constante ROLES ; (4) mostrar/habilitar el cambio de rol solo con <code>manage_roles</code> (hoy no se evalúa: es la desviación "Asignación y cambio de rol"); (5) refrescar el token si la persona editada es el usuario en sesión.

GET /roles · GET /permissions Catálogos · Prioridad alta (bloquea lo anterior)	
Contrato	/roles → [{ code, name, defaultPermissions[] }] . /permissions → [{ code, description, module }] . Permiso: <code>manage_users</code> o <code>manage_roles</code> . Solo lectura (se cargan por migración).
Hoy en el front	Constantes ROLES , ROLE_OPTIONS , ROLE_LABEL , PERMISSIONS y PERMISSION_GROUPS en user-management.model.ts .
Se requiere	Un servicio de catálogos (patrón de CatalogService) que cargue ambos al iniciar sesión y alimente selectores y grid de permisos (agrupado por module). Decidir qué hacer con lo que el back no trae: RoleDef.description (RoleDto no tiene) y la clave local view_catalogs (ver §5.1). El front debe aceptar claves de permiso desconocidas sin romper (PermissionKey es una unión cerrada).

GET /audit-log · GET /users/{id}/audit-log Bitácora · Prioridad media	
Contrato	Query: userId? (solo global), action? , search? , page (0), size (20). Respuesta paginada { content: [{ id, actor{id,displayName} null, target{id,displayName}, action, detail, createdAt }], page, size, totalElements, totalPages } . Permiso <code>view_audit_log</code> (independiente de <code>manage_users</code>). El de un usuario funciona aunque esté dado de baja.
Hoy en el front	UserAudit (/usuarios/auditoria) y la pestaña Historial leen auditLog en memoria, alimentada por appendAudit() .
Se requiere	(1) Servicio con los 2 GET y paginación/filtros del lado servidor en la tabla; (2) reemplazar AuditLogEntry : actor es null cuando lo hizo el sistema (mostrar "Sistema"), target trae id real (hay que resolverlo al uXXXX local para el enlace); (3) vocabulario de acciones distinto : DEV registra created, updated, organization_updated, status_changed, locked, unlocked, role_changed, permissions_changed, password_reset, email_verified, sessions_closed, deleted ; el front usa activated, deactivated, blocked (no existen en el back) y le faltan status_changed, locked, unlocked — actualizar AuditAction , AUDIT_ACTION_LABEL y el filtro; (4) dejar de llamar appendAudit() en las mutaciones reales (el back ya las registra; duplicaría).

POST /users/{id}/reset-password Restablecer contraseña · Prioridad media	
Contrato	Sin body. Respuesta { id, temporaryPassword } (regla NOMBRE+APELLIDO+AÑO). Marca <code>mustChangePassword</code> , revoca todas las sesiones , registra <code>password_reset</code> . 404.
Hoy en el front	UserManagementService.resetPassword() genera una contraseña local (generateTempPassword) y además "desbloquea" si estaba bloqueado; lo usan lista y detalle.
Se requiere	AuthService.resetPassword(id) ; mostrar la contraseña devuelta una sola vez (toast ya existente); quitar el desbloqueo local (la guía no dice que el reset lo haga); reflejar <code>mustChangePassword=true</code> y <code>activeSessions=0</code> . Eliminar password.util.ts si ya nadie lo usa.

POST /users/{id}/close-sessions Cerrar sesiones · Prioridad media	
Contrato	Sin body. Respuesta { id, activeSessions: 0 } . Revoca los refresh tokens (el access token ya emitido vive hasta 15 min). Registra <code>sessions_closed</code> .
Hoy en el front	UserManagementService.closeSessions() pone un contador local en 0 (onCloseSessionsClick) .
Se requiere	AuthService.closeSessions(id) y que el contador "Sesiones activas" salga de activeSessions de GET /users/{id} (§3), no del mock.

DELETE /users/{id}

Baja lógica · **Requiere decisión**

Contrato	Sin body. Respuesta <code>{ success, id }</code> . Baja lógica (conserva historial), revoca sesiones, libera el correo. 409 <code>CANNOT_DELETE_SELF</code> , 404.
Hoy en el front	Opción "Eliminar usuario" retirada: se decidió que el DED habla de <i>desactivar</i> , no eliminar, y el back no la tenía.
Se requiere	Primero decidir si el portal debe ofrecerla (la baja lógica sí conserva historial, lo que acerca el endpoint al DED). Si se agrega: botón con confirmación (no sobre uno mismo), y quitar el registro local : <code>syncFromBackend()</code> hoy nunca elimina usuarios que el back ya no devuelve.

5. Cambios transversales que condicionan la implementación

5.1 Catálogo de permisos: DEV vs. front

Permiso	DEV (guía + migraciones)	Front (roles)	Consecuencia
capture_sales	Sí (migración V2, solo ADMIN)	No existe	Agregarlo al tipo y al grid; gatea POST /sales/capture (\$7).
view_catalogs	No existe	Sí (pantalla /catalogos , menú, guard)	Con permisos leídos del back, /catalogos queda inaccesible para todos. El back no se puede cambiar: el front debe derivarlo localmente o pedir al equipo de back sembrarlo.
Los otros 8	Coinciden (view_dashboard, view_reconciliation, manage_differences, import_settlements, export_reports, manage_users, manage_roles, view_audit_log)	—	—

5.2 Permisos por defecto de cada rol

Rol	DEV (roles)	Front (roles)	Diferencia
ADMIN	Los 9 (incluye capture_sales)	9 (con view_catalogs , sin capture_sales)	Cambia 1 permiso por otro.
ALTAS	manage_users, manage_roles, view_audit_log	Igual	—
CONTABILIDAD	view_dashboard	view_dashboard, export_reports, view_catalogs	Front agrega 2 (matriz 7.16).
TESORERIA	view_reconciliation, manage_differences, import_settlements, export_reports	Anteriores + view_dashboard, view_catalogs	Front agrega 2: contra DEV Tesorería no ve ventas.
COSTOS	ninguno	view_dashboard, export_reports, view_catalogs	Contra DEV, Costos no entra a ninguna pantalla.

Los permisos que ve el front salen del back (AuthUser.permissions), así que la "matriz 7.16 completa" del v3.0 de la comparativa DED **solo se cumple con el seed manual de la DB local**. Con la pila de DEV recién levantada habrá que (a) pedir al back que ajuste los defaults, o (b) aceptar la matriz de DEV y reflejarlo en la comparativa. No es algo que el front pueda resolver solo; hay que decidirlo con el equipo.

5.3 Entorno y configuración del front

Tema	Requerimiento
Gateway y proxy	DEV expone el gateway en :8080 y enruta /auth , /users , /roles , /permissions , /audit-log y /sales . proxy.conf.json solo cubre /auth y /users y apunta a :8082 (mapeo local). Agregar las rutas nuevas y apuntar al puerto real.
Base de datos	El esquema lo crea solo db-migration (V1–V4: capture_sales , correo único entre habilitados, locked_until); el auth-service ya no corre Flyway. La DB actual proviene de feature/login : reconstruir el volumen, levantar con el docker-compose.yml de DEV y volver a sembrar las 26 cuentas demo y sus permisos (el mapa BACKEND_USER_ID del front asume ids 2–27).
CORS y Vercel	El gateway ahora responde CORS con CORS_ALLOWED_ORIGINS (por defecto solo localhost 5173/3000/4200). Fuera del proxy de desarrollo (p. ej. Vercel) el front necesita apiUri absoluto al

	gateway, y ese dominio del portal debe estar en esa variable; <code>vercel.json</code> hoy solo reescribe a <code>index.html</code> .
Renovación de tokens	No lanzar dos <code>/auth/refresh</code> simultáneos con el mismo token (la segunda se interpreta como robo y cierra todas las sesiones). El front tiene un solo timer; cuidar que el refresh posterior a <code>change-password</code> no coincida con él (cancelarlo y reprogramar).
Paginación	Todas las listas del back son paginadas (<code>page</code> desde 0). Usuarios hoy se trae completo con <code>size=100</code> ; bitácora requiere paginar en servidor.

6. Orden sugerido de implementación

#	Entregable	Depende de	Esfuerzo
1	Alinear entorno: reconstruir pila DEV, reseed, proxy/puertos	—	Bajo (operativo)
2	Decisión de permisos: <code>view_catalogs</code> , <code>capture_sales</code> y matriz por defecto (§5.1–5.2)	Equipo back / DED	Decisión
3	Ajustes a lo ya implementado (§3): refresh tras cambio de contraseña, campos nuevos del detalle, subsidiarias/ubicaciones en PATCH, errores, textos 403, unlock→status	—	Bajo–medio
4	<code>GET /roles</code> + <code>GET /permissions</code> y retiro de las constantes	2	Medio
5	<code>PATCH /users/{id}/roles</code> (cambio de rol/permisos con <code>manage_roles</code>)	4	Medio
6	<code>reset-password</code> y <code>close-sessions</code>	3	Bajo
7	Bitácora (<code>/audit-log</code> , <code>/users/{id}/audit-log</code>)	—	Medio–alto (paginación + vocabulario)
8	<code>DELETE /users/{id}</code> (si se decide)	Decisión	Bajo
9	Sales Service (§7)	2	Alto

7. Sales Service (nuevo en DEV, fuera de la guía)

DEV agrega `sales-service` detrás del gateway (`/sales/**`). Hoy "Resumen de venta" usa `MOCK_SALES` . Se documenta porque es lo siguiente a conectar y comparte el modelo de permisos.

Método	Endpoint	Permiso	Qué hace / respuesta
POST	<code>/sales/capture</code>	<code>capture_sales</code>	Captura manual (síncrona, idempotente) de <code>{ ubicacionId, date }</code> desde Facturiza. 200 OK · 207 incompleta · 502 Facturiza no respondió · 409 ya se está capturando · 404 ubicación inexistente. Respuesta con conteos (declarados, capturados, insertados, omitidos, fallidos), monto y páginas.
GET	<code>/sales/captures</code>	<code>view_dashboard</code>	Historial de corridas de <code>ubicacionId</code> + <code>date</code> (manuales y automáticas), la más reciente primero.
GET	<code>/sales/summary</code>	<code>view_dashboard</code>	Resumen del día por ubicación: documentos (conteo, subtotal, impuestos, cargos, total), pagos por medio, impuestos por tributo y extras (descuentos/propinas).

Alcance real para el portal. No hay un listado ni detalle de ventas individuales: `/sales/summary` es un **agregado por día y ubicación**. La tabla de "Resumen de venta", el drawer de detalle fiscal y la exportación CSV **no se pueden alimentar** con

estos endpoints (siguen siendo "Faltante" en la comparativa DED, 7.4). Sí encajan: el botón **Reprocesar** (→ POST /sales/capture , con rango/ubicación reales; ya tiene el permiso capture_sales), un resumen diario y el historial de capturas. ubicacionId es el id numérico de AuthUser.ubicaciones , lo que elimina el puente por nombre (LABEL_TO_STORE).

8. Preguntas abiertas para el equipo de back

- ¿ PATCH /users/{id}/unlock se conserva o desaparece a favor de status: active ? (la guía no lo menciona).
- ¿Se sembrará view_catalogs , o la pantalla de catálogos cambia de permiso?
- ¿Se ajustan los defaults de Contabilidad/Tesorería/Costos (§5.2) a lo que decidió el DED 7.16?
- ¿Habrá endpoint para listar/detallar ventas individuales (7.4) o solo el agregado diario?
- ¿El reset de contraseña debe desbloquear la cuenta si estaba bloqueada? (la guía no lo indica).

9. Historial de versiones

Versión	Fecha	Cambios
1.0	06-Oct-2026	Primer análisis: front ab89ce2 vs. back DEV de23127 y guía Guía_Endpoints_Usuarios_Roles_Permisos .